

Can an LLM help a privacy expert do LINDDUN threat modeling?

Grounded, per-flow threat generation over LINDDUN Pro —
with every citation independently verified, not self-reported.

2

EVALUATION SCENARIOS

140

GOLD-STANDARD THREATS

4

LIVE GENERATION RUNS, WEEKS 6–7

Pipeline mechanics · evaluation methodology & first real numbers · scenario roadmap

From "regulation-grounded" to a broader question

Where this started

Weeks 1–4

Traceable, *regulation-grounded* privacy threat modeling — every threat citing a LINDDUN node, a DFD location, and a specific regulatory provision (COPPA, GDPR, HIPAA, GINA...), each independently verified.

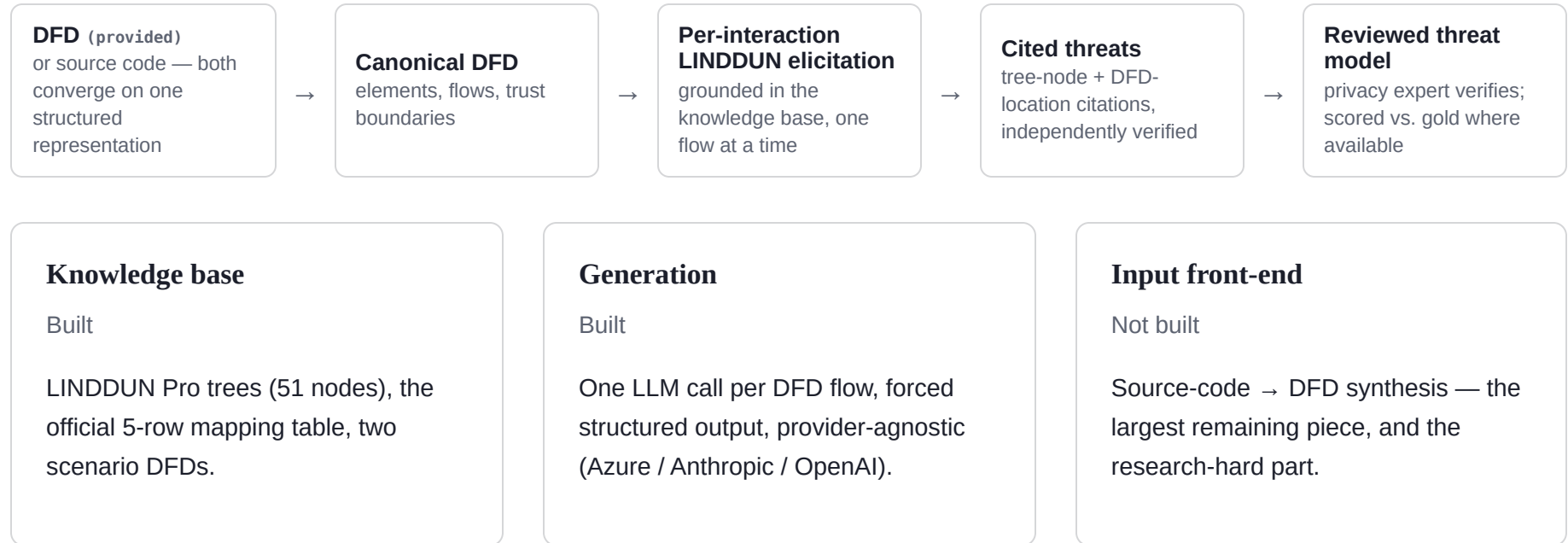
Where it is now

Week 5 pivot, per advisor discussion

Regulatory-citation grounding dropped entirely. The question is broader and simpler: **can an LLM, grounded in the LINDDUN Pro methodology, help a privacy expert conduct a LINDDUN-based privacy risk analysis they can trust?**

Traceability — a methodology-node citation and a DFD-location citation, both independently checked against the knowledge base — stays central. It's the mechanism that makes "trust" checkable at all.

One target pipeline, two input modes



Grounded vs. ungrounded, mechanically

Same LLM, same forced schema, same independent verifier downstream.

The only difference is what the model is told *before* it answers.

GROUNDING

Mapping-table gate

is (src type → dst type) one of 5 valid Process-mediated rows?

Prompt = flow text + applicable types + full tree-node list

explicit, inlined methodology context — model picks only from what's listed

UNGROUNDING (ablation)

No gate

every flow gets a call, nothing is ever skipped

Prompt = flow text only

no mapping table, no tree nodes — model free-associates from training knowledge

A flow that fails the gate is **never sent to the LLM** in grounded mode — not a low-quality answer, no call at all.

Same flow, two very different prompts

grounded

Flow DF1: Parent User (ExternalEntity) -> Authentication Service (Process)
Flow description: parent registration (email, password, name, govt ID, code)

Interaction: ExternalEntity -> data flow -> Process
Applicable LINDDUN types: L, I, Nr, D, Dd, U, Nc

Relevant threat-tree nodes to consider:

- L.1.1 – Unique identifier: ...
- Dd.1.1 – Data type sensitivity: ...
- Nc.1.1 – Unlawful processing or disclosure: ...
- ... 51 nodes total for this interaction

tree_node must be one of the node ids listed above.

ungrounded

Flow DF1: Parent User (ExternalEntity) -> Authen
Flow description: parent registration (email, pa

Identify any privacy threats for this flow. For
classify it under a LINDDUN type (L, I, Nr, D, D
and give your best LINDDUN Pro threat-tree node

(no reference material provided –
model relies entirely on training knowledge)

Every citation is checked, not trusted

`generation/verify.py` re-derives ground truth from the knowledge base files directly — a retrieval bug or a fabricated citation can't slip through.

node_valid

Does `tree_node` actually exist under the claimed `threat_type` in `threat_trees.json`?

type_applicable

Is that threat type genuinely applicable at this flow's interaction, per the mapping table?

location_valid

Does `originator_id` resolve to a real element or flow endpoint in `dfd.json`?

A third citation type — a specific regulatory provision (COPPA §312.5, HIPAA §164...) — existed through Week 4 and was dropped in the Week 5 pivot. These two remain.

Matching, then three ways of reading a miss

Matching

eval/match.py

Greedy, one-to-one: same threat_type, and the same flow — by flow-id string (KidsTube) or by (source, destination) location (Genomic). --strict also requires the exact tree node.

Reachability breakdown

eval/reachability.py — new, Week 6

Every unmatched gold threat is classified, not just counted as a miss:

reachable_but_missed – a real recall failure

structurally_unreachable – skipped before any LLM call

unresolved_location – no single flow to anchor to

Reuses generate.py's own gate check — so "unreachable" here can't drift from what the pipeline actually skips.

Four runs, both scenarios, both modes

RUN	N GEN	TP	FP	FN	P	R	F1	CITATION ✓	RECALL, ADJ.
KidsTube – grounded	130	33	97	8	.25	.80	.39	1.00	.80
KidsTube – ungrounded	113	28	85	13	.25	.68	.36	0.95	.68
Genomic – grounded	193	45	148	54	.23	.45	.31	1.00	.64
Genomic – ungrounded	249	67	182	32	.27	.68	.39	0.79	.77

KidsTube numbers are Week 7's re-score against the corrected 41-threat gold standard (see Finding 3) — same generated output as Week 6, fairer scoring. Precision still reads low (.23–.27) — both gold standards are curated catalogs, not exhaustive ground truth, so an unmatched generated threat may be a real miss or a real threat the gold standard simply didn't itemize.

KidsTube, by LINDDUN category

grounded

TYPE	TP	FP	FN	P	R	F1
L	6	11	0	.35	1.00	.52
I	4	12	1	.25	.80	.38
Nr	2	10	0	.17	1.00	.29
D	1	9	1	.10	.50	.17
Dd	11	19	4	.37	.73	.49
U *	4	20	0	.17	1.00	.29
Nc *	5	16	2	.24	.71	.36
ALL	33	97	8	.25	.80	.39

* Non-compliance and Unawareness — flagged as hardest to automate (see slide 8's report format).

ungrounded

TYPE	TP	FP	FN	P	R	F1
L	5	12	1	.29	.83	.43
I	4	15	1	.21	.80	.33
Nr	2	10	0	.17	1.00	.29
D	2	18	0	.10	1.00	.18
Dd	6	5	9	.55	.40	.46
U *	4	12	0	.25	1.00	.40
Nc *	5	13	2	.28	.71	.40
ALL	28	85	13	.25	.68	.36

Genomic, by LINDDUN category

grounded

TYPE	TP	FP	FN	P	R	F1
L	11	9	6	.55	.65	.59
I	5	21	9	.19	.36	.25
Nr	1	16	9	.06	.10	.07
D	5	14	3	.26	.62	.37
Dd	6	40	3	.13	.67	.22
U *	11	21	21	.34	.34	.34
Nc *	6	27	3	.18	.67	.29
ALL	45	148	54	.23	.45	.31

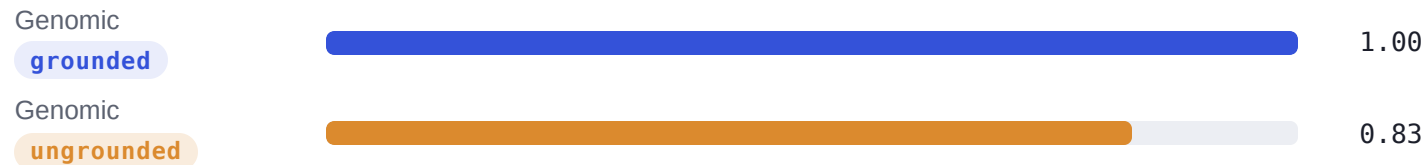
* Non-compliance and Unawareness — flagged as hardest to automate. Nr (Non-repudiation) stands out grounded-side: 1 TP / 9 FN — the smallest, hardest category in this scenario.

ungrounded

TYPE	TP	FP	FN	P	R	F1
L	17	21	0	.45	1.00	.62
I	10	30	4	.25	.71	.37
Nr	6	28	4	.18	.60	.27
D	8	43	0	.16	1.00	.27
Dd	4	9	5	.31	.44	.36
U *	15	18	17	.45	.47	.46
Nc *	7	33	2	.17	.78	.29
ALL	67	182	32	.27	.68	.39

Grounding still measurably improves citation reliability

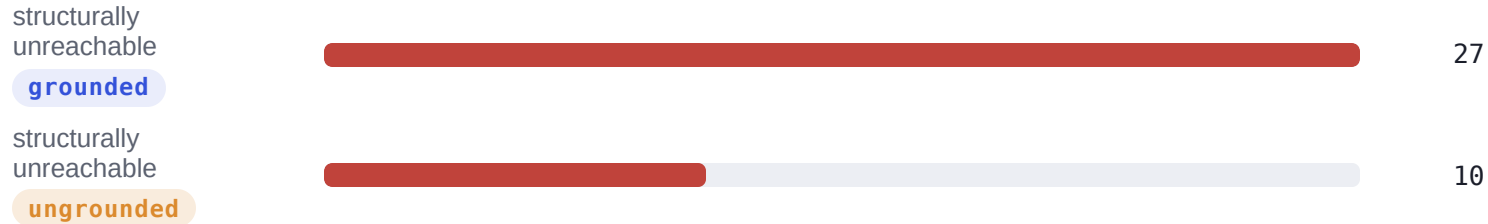
Even with regulatory citations gone, the same pattern from Week 4 shows up in what remains: `type_applicable_rate` — is the asserted LINDDUN type actually valid at this interaction?



17% of the time, ungrounded asserts a type the mapping table says doesn't apply there — it has nothing telling it otherwise, so it guesses something plausible-sounding instead.

Grounding trades recall for that reliability

Genomic grounded skips 6 of 39 flows outright — the mapping table says no
Process mediates, so the LLM is never called. Ungrounded skips nothing.



Ungrounded still gets queried on those 6 flows and coincidentally matches 17
of the 27 gold threats sitting there. Not better reasoning — just no gate
stopping it from trying.

KidsTube's hidden ceiling — found, then fixed

4 of KidsTube's original 36 gold threats described something spanning **more than one flow at once** — structurally unmatched by a per-flow pipeline, invisible until eval was run for the first time.

GOLD #	SPANNED	RESOLUTION
10	2 flows, DS2 profile	deduplicated — combination <i>is</i> the risk
18	2 flows, platform-wide	deduplicated — combination <i>is</i> the risk
21	2 flows, JWT to each party	split clean — same defect, independently
29	3 flows, 3 stores	split clean — same defect, independently

Not a uniform fix. #21/#29's flows each independently carry the identical vulnerability — splitting loses nothing. #10/#18's own descriptions say the risk is the *combination* across flows — so those were deduplicated onto each contributing flow rather than forced into one, accepting a documented double-counting trade-off instead of fabricating weaker content.

36 → 41

GOLD THREATS (NET +5)

.69 → .80

GROUNDING RECALL — SAME OUTPUT, FAIR SCORING

Next: 2–3 new scenarios

Beyond KidsTube (real code) and Genomic (authoritative external source)
— a deliberate mix of both sourcing styles.

01 **Nextcloud** `code · build first`

File-sharing + federation subsystem

Real open-source PHP codebase; federated sharing exercises the code → DFD differentiator and diversifies interaction types past Genomic's EE ↔ EE gap.

02 **LINDDUN Pro Tutorial's worked example** `needs feasibility check`

Methodology-authoritative

Same source PDF as `threat_trees.json` — if a full worked example exists, guaranteed-compatible node IDs, cheapest to transcribe.

03 **NIST PRAM published examples** `external authoritative`

usnistgov/PrivacyEngCollabSpace

Government-authored, different domain — needs a remapping effort similar to Genomic's own.

04 **Mastodon** `stretch`

ActivityPub federation

Cross-instance flows stress-test EE ↔ EE further, once there's practice from Nextcloud.

Where things stand

Done

- Regulatory-citation grounding fully removed; research question reframed
- Reachability-status tooling built and validated against the published 70/27/2 genomic split
- First-ever live generate + eval runs, both scenarios, grounded and ungrounded
- KidsTube's multi-flow gold-standard gap diagnosed and resolved (36 → 41 threats, 41/41 reachable)

Full detail: PIPELINE.md · WEEK5–7_REPORT.md

Open

- effective_type internal-staff reclassification — still pending advisor sign-off
- The #10/#18 duplicate-scoring decision — a real methodological call, needs sign-off before citing 41/41 in the paper
- Manual spot-check of "false positive" generated threats — precision numbers need this caveat resolved
- Nextcloud scenario — not yet started